

ISO 27001

Risk Assessment Report

SecureHealth Inc. — Cloud Infrastructure Security Review

Prepared by: Solomon Mwaura

Role: Junior Security Engineer

Date: March 15, 2026

Standard: ISO 27001:2022 | HIPAA 45 CFR §164.312

Status: **CONFIDENTIAL** — For Authorised Personnel Only

CRITICAL RISKS: 3

HIGH RISKS: 2

ASSETS ASSESSED: 5

SECTION 1 — RISK ASSESSMENT OVERVIEW

1.1 Scope & Objectives

This assessment covers SecureHealth Inc.'s transition to cloud-based storage and operations, focusing on the protection of Protected Health Information (PHI) stored in AWS S3 and patient management systems hosted on Azure. The primary objectives are to:

- Ensure full HIPAA compliance across all cloud-hosted systems and data stores.
- Identify security gaps in current cloud configurations — particularly unencrypted storage and weak access controls.
- Align security controls with ISO 27001:2022 standards to prevent data breaches and regulatory penalties.
- Provide a prioritised, actionable risk treatment plan with clear ownership and timelines.

1.2 Methodology

This assessment follows the ISO 27001:2022 risk management process, structured across four stages:

Step	Stage	Description
01	Asset Identification	Review asset inventory to determine high-value targets including PHI stores, virtual machines, and vendor APIs.
02	Threat & Vulnerability Assessment	Analyse system logs and policies to identify active and potential threats against each critical asset.
03	Risk Evaluation	Apply a quantitative scoring model: Risk Score = Likelihood (1–5) × Impact (1–5). Scores ≥16 are Critical.
04	Risk Treatment	Recommend specific technical and administrative controls aligned to NIST and ISO 27001 frameworks.

SECTION 2 — IDENTIFIED RISKS & ANALYSIS

2.1 Critical Assets & Associated Threats

The following five assets were identified as high-value targets during asset inventory review. Each presents specific threat vectors relevant to SecureHealth Inc.'s cloud migration:

Asset	Location	Primary Threat	Data Sensitivity
Cloud Storage	AWS S3	Data exfiltration via unencrypted PHI buckets	CRITICAL — PHI at rest
Virtual Machines	Azure	Malware/ransomware via unpatched OS	HIGH — Patient software
EHR System	Cloud-hosted	Insider threat via unencrypted file uploads	CRITICAL — Medical records
Vendor API	Third-party billing	Unauthorised access via missing MFA	HIGH — Financial & PHI
Remote Access	VPN/Internet	Unauthorised login from unknown IPs	HIGH — Full system access

2.2 Risk Register

Risks are scored using the formula: Risk Score = Likelihood (1–5) × Impact (1–5). Scores of 16 and above are classified as Critical and receive immediate treatment priority.

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Score	Mitigation
HRR-001	Cloud Storage (AWS S3)	Data Breach	Unencrypted PHI detected in logs	4	5	20 CRITICAL	Enforce AWS KMS server-side encryption (SSE-KMS) on all S3 buckets
HRR-002	Virtual Machines (Azure)	Ransomware	30-day patch window — too long	3	5	15 HIGH	Reduce patch cycle to 72 hours via automated patch management
HRR-003	EHR System	Insider Threat	Unencrypted file upload policy violation	4	5	20 CRITICAL	Implement Cloud DLP to block unencrypted uploads automatically
HRR-004	Vendor API (Billing)	Data Leakage	Lack of MFA for third-party access	3	4	12 HIGH	Mandate MFA for all vendors; enforce signed BAAs
HRR-005	Remote Work	Unauthorised Access	Failed logins from unknown IPs in logs	4	4	16 CRITICAL	Implement geo-blocking and VPN with MFA for all remote access

Table 1 — Risk Register | Scoring: 16–25 = Critical (Red) | 9–15 = High (Amber) | 1–8 = Low (Green)

2.3 Threat Analysis & Potential Impact

DATA BREACH IMPACT — HRR-001 & HRR-003

Log entry ERROR — PHI Access Policy Violation confirms unencrypted patient data is actively entering the cloud. A breach would trigger legal action under the HITECH Act with fines exceeding \$1 million. Beyond financial penalties, patient trust and SecureHealth Inc.'s operating licence would be at serious risk.

UNAUTHORISED ACCESS IMPACT — HRR-005

Log entry WARN — Unauthorised access attempt detected indicates active external probing of the network perimeter. A successful compromise could result in complete system takeover, ransomware deployment, and the full exfiltration of PHI records.

BUSINESS CONSEQUENCE

Beyond financial fines, a security incident at SecureHealth Inc. would result in significant reputational damage, potential CMS sanctions, and the loss of ability to provide critical patient care — an outcome far more costly than implementing the controls described in this report.

SECTION 3 — RISK MITIGATION STRATEGIES

3.1 Risk Prioritization

Risks were prioritised based on their Risk Score (Likelihood × Impact). All risks scoring 16 or above are classified Critical and addressed before lower-priority items. The three Critical risks all relate to PHI exposure, confirming that data protection is the primary security concern at SecureHealth Inc.

#	Risk ID	Description	Risk Score	Priority	Addressed By
1	HRR-001	Unencrypted PHI in AWS S3 (detected in active logs)	20 — CRITICAL	IMMEDIATE	AWS KMS SSE
2	HRR-003	Insider threat via unencrypted EHR file uploads	20 — CRITICAL	IMMEDIATE	Cloud DLP
3	HRR-005	Active external probing — failed logins from unknown IPs	16 — CRITICAL	IMMEDIATE	Geo-block + VPN MFA
4	HRR-002	Ransomware risk from 30-day VM patch window	15 — HIGH	30–90 Days	Auto Patch Mgmt
5	HRR-004	Vendor API data leakage via missing MFA	12 — HIGH	30–90 Days	Vendor MFA + BAA

3.2 Mitigation Plan & Timeline

The following table presents the full mitigation plan, structured by implementation timeline. Immediate actions address all Critical risks. Long-term and ongoing actions address High risks and establish continuous improvement processes.

Timeline	Action	Risk ID	Priority
IMMEDIATE	Enable SSE-KMS encryption on all AWS S3 buckets storing PHI.	HRR-001 / 003	Critical
IMMEDIATE	Enable MFA for all remote employees and all vendor API access.	HRR-004 / 005	Critical
IMMEDIATE	Implement IP whitelisting — block flagged IP 203.0.113.12.	HRR-005	Critical
30–90 DAYS	Deploy automated patch management for Azure VMs (72-hour SLA).	HRR-002	High
30–90 DAYS	Integrate Cloud DLP to block unencrypted file uploads to EHR.	HRR-003	High
ONGOING	Implement IAM logging to map every action to a verified identity.	All	Medium
ONGOING	Deploy AWS GuardDuty for AI-driven automated threat detection.	All	Medium
QUARTERLY	Conduct tabletop exercises simulating a HIPAA breach scenario.	All	Medium

Table 2 — Mitigation Plan | Prioritised by risk score and implementation complexity

SECTION 4 — COMPLIANCE & SECURITY BEST PRACTICES

4.1 ISO 27001 Control Alignment

The following table maps each proposed mitigation directly to its corresponding ISO 27001:2022 control domain, demonstrating how the risk treatment plan aligns with the international standard for information security management.

ISO 27001 Control	Implementation at SecureHealth Inc.
A.10 — Cryptography	Enforcing AES-256 encryption for PHI at rest (S3/EHR) and TLS 1.3 for all data in transit.
A.12.6.1 — Vulnerability Mgmt	Reducing VM patch window from 30 days to 72 hours via automated patch management tools.
A.13.1.1 — Network Security	VPN with MFA and IP geo-blocking to protect remote access data flows.
A.9.4 — Access Control	Enforcing MFA for all internal users, remote workers, and third-party vendor APIs.
A.18.1 — HIPAA Compliance	Documenting all controls as Good Faith effort under 45 CFR §164.312 Technical Safeguards.

Table 3 — ISO 27001:2022 Control Mapping

4.2 Regulatory & HIPAA Compliance Considerations

All proposed mitigations directly fulfill HIPAA Technical Safeguards under 45 CFR §164.312. Specifically:

- §164.312(a)(1) — Access Control: MFA implementation and IAM logging satisfy this requirement.
- §164.312(a)(2)(iv) — Encryption and Decryption: AWS KMS SSE-KMS and TLS 1.3 in transit satisfy this requirement.
- §164.312(b) — Audit Controls: AWS GuardDuty and IAM logging provide the required audit trail.
- §164.312(e)(2)(ii) — Encryption in Transit: TLS enforcement on all inter-system communications satisfies this safeguard.

By formally documenting this risk assessment, SecureHealth Inc. demonstrates a Good Faith effort to comply with ISO 27001, which can materially reduce the severity of financial penalties in the event of an audit or regulatory investigation.

4.3 Security Assessment Methodology Comparison

Factor	Risk-Based (ISO 27001)	Vulnerability Scanning
Primary Focus	Business context, data value, and risk to operations	Technical flaws, missing patches, and misconfigurations
PHI Protection	High — directly prioritises patient data by business value	Medium — identifies technical gaps but not business context
Output	Risk register with treatment plans and ownership	CVE list with severity scores
Best For SecureHealth	✓ Superior — addresses regulatory and operational risk together	Supplementary — weekly scans catch technical drift in cloud

Factor	Risk-Based (ISO 27001)	Vulnerability Scanning
Frequency	Annually + after major changes	Weekly / continuous

Conclusion: For SecureHealth Inc., a Risk-Based Assessment is superior as it directly prioritises PHI protection. However, it must be supported by weekly automated Vulnerability Scans to catch technical configuration drift in the cloud environment.

SECTION 5 — REFLECTION & CONTINUOUS IMPROVEMENT

5.1 Effectiveness of Risk Mitigation

Implementing AWS KMS encryption and Cloud DLP directly addresses the ERROR — PHI Access Policy Violation and WARN — Unencrypted file upload entries found in the access logs. These measures convert a manual security policy into a technical hard-stop, meaning the control is enforced automatically regardless of user behaviour. This significantly lowers the residual risk score of HRR-001 from 20 to an estimated 4 post-implementation.

The MFA mandate for remote employees and vendor API access directly addresses the WARN — Unauthorised access attempt log entries. By requiring a second factor, even fully compromised credentials cannot be used to access systems without the physical device. This converts HRR-005 from a Critical risk to a Low residual risk.

5.2 Challenges & Adjustments

A primary challenge encountered during this assessment was identifying the 'UNKNOWN' user in the access logs. Actions attributed to an unknown identity cannot be investigated, attributed, or remediated — they represent a complete visibility gap in the security posture. This highlights a fundamental deficiency in the current logging infrastructure.

The recommended corrective action is to implement comprehensive IAM (Identity and Access Management) logging across all AWS and Azure resources. Every API call, resource access, and configuration change must be mapped to a specific, verified identity. AWS CloudTrail and Azure Monitor together provide this capability at minimal cost.

5.3 Future Recommendations

Recommendation	Description	Timeline
AWS GuardDuty	Deploy AI-driven automated threat detection. GuardDuty continuously monitors CloudTrail, VPC Flow Logs, and DNS logs for malicious activity and generates actionable findings automatically.	Immediate
IAM Logging	Implement full CloudTrail and Azure Monitor logging to map every system action to a verified identity, eliminating UNKNOWN user events.	Immediate
Tabletop Exercises	Conduct quarterly exercises simulating a HIPAA breach scenario to test the IT and security team's incident response capability and identify response gaps.	Quarterly
Automated Vendor Reviews	Automate Business Associate Agreement (BAA) reviews to ensure vendor access is revoked or updated whenever an API usage pattern changes unexpectedly.	Ongoing
Penetration Testing	Commission an annual third-party penetration test targeting the AWS S3 configuration, Azure VM access, and vendor API authentication to validate control effectiveness.	Annually